GOVERNANCE, PRIVACY & BUSINESS CONSULTING · LESSON 3 OF 5

Data Ownership, Stewardship, Retention and Privacy Law: GDPR and India's DPDP Act

Assign clear ownership and stewardship to each dataset, set and enforce retention periods, and apply the core principles of privacy law, including data minimisation, consent and purpose, individual rights and breach reporting under the EU's GDPR and India's Digital Personal Data Protection Act, 2023.

Gap-fill lesson | ✦ 2026 | Intermediate | ⏱ 120 min

By the end of this lesson you can

- Assign an owner and a steward to a dataset and state their duties
- Write a retention rule and enforce it with a scheduled deletion job
- Apply data minimisation, purpose limitation and consent in a dataset
- Explain the main rights and duties under GDPR and India's DPDP Act, 2023

Datasets used

`customers.csv`

Ownership and stewardship

Every dataset needs two named people. The **owner** decides who may use it and for what purpose. The **steward** keeps it accurate, documented and within its rules day to day. Without them, a dataset becomes a shared folder that everyone uses and nobody answers for.

Role	Decides	Does	Answers when
Owner	Who may access it; the purpose; the retention period	Approves access requests and changes to the purpose	A regulator or auditor asks why data is held
Steward	How it is defined, checked and documented	Runs quality checks, maintains the dictionary, applies the rules	A number is questioned or a field is unclear
Custodian (often engineering)	How it is stored and protected	Applies access controls, backups and deletion jobs	The system is breached or deletion fails

CASE STUDY **The file nobody could delete**

A marketing team had kept a customer export for four years. Nobody knew whether it was still used, who had copies or what it contained. When a customer asked for their data to be deleted, the company could not answer within the legal deadline. A named owner and a retention rule would have turned that into a routine request.

Retention: how long data is kept

A **retention period** states how long a dataset is kept and why. It must be written in policy and enforced by a scheduled job, not by memory.

Dataset	Purpose	Retention	Deletion
Call recordings	Quality review	90 days	Scheduled job deletes files older than 90 days and logs each deletion
Order history	Accounting and returns	7 years (as required by tax law)	Archived to cold storage, then deleted at the end of the period
Marketing leads without consent	Contact	Deleted after 30 days	Daily job removes unconsented leads

Retention rules often conflict: accounting may require seven years while privacy law says keep data no longer than needed. Resolve the conflict by keeping only the fields the legal purpose requires, and deleting the rest sooner.

Python

```python
import pandas as pd

# A retention check: which records are past their retention period?
records = pd.DataFrame({
    "record_id": ["r1", "r2", "r3"],
    "created": pd.to_datetime(["2025-01-10", "2025-10-01", "2024-06-01"]),
    "purpose": ["lead without consent", "order history", "call recording"],
})
retention_days = {"lead without consent": 30, "order history": 365 * 7, "call recording":
90}
as_of = pd.Timestamp("2025-11-11")

records["age_days"] = (as_of - records["created"]).dt.days
records["retention_days"] = records["purpose"].map(retention_days)
records["delete_now"] = records["age_days"] > records["retention_days"]
print(records[["record_id", "purpose", "age_days", "retention_days",
"delete_now"]].to_string(index=False))
```

OUTPUT

```
record_id              purpose  age_days  retention_days  delete_now
       r1 lead without consent       305              30        True
       r2        order history        41            2555       False
       r3       call recording       528              90        True
```

The check is simple, and that is the point: a rule expressed as code can run every night and produce a log of what it deleted.

Data minimisation and purpose

Two principles run through every privacy law. **Data minimisation** means collecting and keeping only what the purpose needs. **Purpose limitation** means using the data only for the purpose it was collected for, unless the law allows another use.

Python

```python
import pandas as pd

customers = pd.read_csv("customers.csv")
print("columns before:", list(customers.columns))

# The campaign needs an identifier, region and a consent flag, and nothing else
campaign = customers[["customer_id", "region"]].assign(consent=True)
print("columns for campaign:", list(campaign.columns))
```

OUTPUT

```
columns before: ['customer_id', 'customer_name', 'segment', 'city', 'state',
'region']
columns for campaign: ['customer_id', 'region', 'consent']
```

A marketing dataset that carries phone numbers, addresses and dates of birth for an email campaign breaks minimisation, even if nobody misuses it.

Consent

Consent must be specific, informed, freely given and recorded. Record what the person agreed to, when, and how, and check the record before each use. A consent flag in a table is only as good as the process that sets it: a flag that is never updated after a withdrawal is a breach.

GDPR (European Union)

The General Data Protection Regulation applies to personal data of people in the EU, and to organisations outside the EU that offer goods or services to them or monitor them. Its principles include lawfulness, purpose limitation, minimisation, accuracy, storage limitation, security and accountability. Individuals have rights to access, correction, erasure, restriction and portability, and organisations must report certain breaches within 72 hours.

India's Digital Personal Data Protection Act, 2023

India's DPDP Act, 2023 governs the processing of digital personal data in India, and some processing outside India that relates to goods or services offered in India. It is built on consent and legitimate uses, sets duties for **data fiduciaries** (organisations that decide how personal data is processed) and rights for **data principals** (the individuals). Rights include access to a summary of processing, correction and erasure. Organisations must give notice, have a grievance mechanism, protect data with reasonable security, and report breaches to the Data Protection Board and to affected individuals as the Act and its rules require. Check the current rules and notifications with counsel, because implementation details are set out in subordinate rules.

Principle	GDPR	India DPDP Act, 2023
Lawful basis or consent	Several lawful bases, including consent	Consent or specified legitimate uses
Purpose limitation	Yes	Yes
Individual rights	Access, correction, erasure, portability, and more	Access to summary, correction, erasure, grievance
Breach reporting	Within 72 hours to the authority, where required	To the Board and affected individuals, as prescribed
Children's data	Special protection	Verifiable parental consent for children

::::warn This is not legal advice These summaries help analysts recognise the principles. Whether a particular dataset is lawful, how long it may be kept, and what a breach notice must say are legal questions. Involve the company's legal or privacy function before collecting new personal data. ::::

A privacy checklist for any dataset

- [ ] A named owner and steward, written in the catalogue.
- [ ] The purpose written down, and each field justified by it.
- [ ] Minimisation: fields not needed for the purpose are dropped or never collected.
- [ ] Consent or other lawful basis recorded, with a date and a way to withdraw.
- [ ] Retention period set, with a scheduled deletion job and a log.
- [ ] Access restricted to the people who need it, reviewed each quarter.
- [ ] A process for access, correction and deletion requests, with a deadline.
- [ ] A breach response plan that names who decides and who notifies.

INTERVIEW CORNER **What does data minimisation mean for an analytics team?**

Collect and keep only the fields that a stated purpose needs, and remove the rest as early as possible. For analysis, that often means aggregating or pseudonymising before the data leaves the source, so that analysts see what they need and nothing more.

::::key What to remember - Each dataset has an owner (decides) and a steward (keeps it accurate). - Retention is a written rule, enforced by a scheduled, logged deletion. - Minimisation and purpose limitation are the core principles of privacy law. - Consent must be recorded and updated when withdrawn. - GDPR and India's DPDP Act share principles; their details differ, so check with counsel. ::::

Quick quiz

5 questions · tap an answer to check it

1. What does the data owner decide?

A How the database is backed up

B Who may access the dataset and for what purpose

C The chart colours

D The server model

Answer: B. The owner is accountable for access and purpose.

2. What makes a retention rule effective?

A A statement in a meeting

B A written rule enforced by a scheduled job with a deletion log

C A promise by one person

D A comment in the code

Answer: B. Rules must run automatically to be reliable.

3. Which principle says only the fields the purpose needs should be collected?

A Accuracy

B Storage limitation only

C Data minimisation

D Portability

Answer: C. Minimisation limits what is collected and kept.

4. Why is a consent flag that is never updated a problem?

A It takes space

B Withdrawn consent is still treated as given, which breaks the law and the promise to the person

C Flags cannot be stored

D It is always correct

Answer: B. A stale flag misrepresents the person's choice.

5. Which law applies to digital personal data processed in India?

A GDPR

B The Digital Personal Data Protection Act, 2023

C The Copyright Act

D The Companies Act only

Answer: B. India's DPDP Act is the governing act for digital personal data.

EXERCISE **Write a retention and minimisation plan**

For a customer dataset with name, phone, email, address, date of birth, purchase history and support call recordings, write: the owner and steward roles, the purpose, the fields to keep, the retention period for each, the consent record needed, and the deletion job. Mark one item for legal review and say why.

Show solution (worked answer)

Expected: drop date of birth unless a stated purpose needs it; keep purchase history for the accounting period; delete call recordings after a short period; record consent with date and channel; flag any retention period that conflicts with a legal requirement for legal review.

Practise more online

Free, trusted places to test yourself on this topic. Links open the original site in a new tab.